

	Lỗi	Bối cảnh	Lời thoại	Lưu ý
Intro			Một trường đại học đang triển khai hệ thống EduPortal, nền tảng nội bộ phục vụ quản lý khóa học MOOC, điểm số, đề tài tốt nghiệp và nộp minh chứng của sinh viên. Hệ thống đang được hoàn thiện để đưa vào sử dụng rộng rãi trong khoa. Trong đó, A là trưởng nhóm, lập trình viên chính xây dựng EduPortal. B là giáo viên hướng dẫn kiêm quản trị hệ thống. C là thành viên cùng nhóm nhưng đang trượt đề tài tốt nghiệp.	
Cảnh 1	1. Form đăng nhập hệ thống dính SQL Injection	Trong phòng Lab. A đang demo EduPortal cho B.	B: Sắp báo cáo tiến độ rồi, cho cô xem tổng quan đi em. (A mở trang đăng nhập, B tò mò tự gõ vào ô Username: admin' OR '1'='1' -- , ô mật khẩu để trống bất kỳ, rồi bấm "Đăng nhập". Màn hình chuyển thẳng vào trang quản trị.) B: (khựng lại) Ơ... cô gõ bậy bạ vậy mà vô được trang quản trị luôn á?	
	2. Bình luận khóa học dính Stored XSS		A: (cười trừ, mắt vẫn dán vào phần khác) Chắc tài khoản demo em chưa xóa á cô, để mai em check, giờ xem tiếp phần MOOC cho kịp giờ lab. (A chuyển sang trang bình luận khóa học. Cô mở khung bình luận, gõ: <code><script>alert('test')</script></code> rồi bấm Gửi cho vui. Trang load lại, một hộp thoại popup ghi "test" bật lên ngay giữa màn hình.) A: (giật mình rồi bật cười) Ủa gõ ký tự lạ mà nó chạy thành popup luôn kìa, chắc em quên lọc mấy ký tự đặc biệt. Kệ đi cô, không ảnh hưởng chức năng chính đâu. B: (nhìn đồng hồ) Thôi để ý sau nhé, giờ demo tiếp phần nộp minh chứng....	
	3. Sửa ID trên URL để xem điểm của nhóm khác (IDOR)		B: Em test kỹ giùm cô mấy chức năng trước khi mình launge cho cả khoa nha, có gì lạ báo cô liền. C: Dạ được cô. C: Chức năng xem điểm... để test thử coi có bug gì không. (C đang ở trang xem điểm, URL hiện eduportal.edu/diem?ma_de_tai=104. C sửa tay số 104 thành 105 rồi Enter. Trang hiện bảng điểm của một nhóm khác.) C: Dễ vậy luôn hả, đổi mỗi con số thôi mà. (khựng lại) Ơ, đề tài mình bị rớt mà nhóm khác được duyệt... (im lặng một lúc) ...thôi, test tiếp đã.	
	4. Module minh chứng cho phép upload file PHP		C: Mà khoan... nếu điểm với thông tin đề tài của nhóm khác còn xem được, không biết mấy chỗ khác có kiểm tra kỹ hơn không. (C mở mục "Nộp minh chứng đề tài", chọn file bao_cao.php (đổi đuôi từ .pdf) kéo thả vào ô upload. Hệ thống báo "Tải lên thành công — bao_cao.php".) C: (ồ lên khe khẽ) Up lên được thiệt luôn? Nó đâu có kiểm tra đuôi file gì đâu ta...	
	5. Đường dẫn file dính Directory Traversal.		C: Upload được file gì cũng cho qua... vậy cái chỗ đọc tài liệu này có kiểm tra đường dẫn không? (C bấm vào mục Xem tài liệu tham khảo. URL hiện dạng eduportal.edu/view?file=....) C: Có tham số file luôn... (C thử thay giá trị bằng: ?file=../../../../etc/passwd rồi Enter. Màn hình hiện nội dung một file hệ thống.) C: Wow. Đi vòng vòng vậy mà đọc được cả file trên server luôn á?	

Cảnh 2	6. Không có mã Token chống CSRF	Chiều hôm đó, B giao cho C nhiệm vụ test web, sau đó C ở lại phòng Lab một mình	(Sau khi xem được file hệ thống, C tiếp tục lướt qua các chức năng khác. Đúng lúc đó, điện thoại C hiện tin nhắn của đứa bạn.) Tin nhắn: Có tài liệu hướng dẫn làm khóa luận mới, mọi người vào xem nhé: tailieu-khoaluan.edu C: Ủa, có tài liệu mới hả? Để coi thử. (C bấm vào đường link. Một trang web đơn giản hiện ra với dòng chữ: “Đang tải tài liệu...”. Trong lúc trang đang tải, phía sau màn hình xuất hiện một yêu cầu gửi đến EduPortal. Không cần C bấm thêm nút nào.) C: Ủa gì vậy? Mình có làm gì đâu? C: Để mở DevTools lên xem thử. (Màn hình quay sang DevTools/Network, xuất hiện request:) POST /api/cap-nhat-thong-bao Cookie: SESSION_ID=abc123 (Request không có CSRF Token. EduPortal trả về: 200 OK.) (Màn hình chuyển sang EduPortal. Một thông báo hiện lên: “Cập nhật thành công.”) C: Khoan... Mình đang coi tài liệu thôi mà? Sao bên EduPortal lại vừa có thao tác? (C nhìn lại trang, nhưng trang vẫn chỉ hiện “Đang tải tài liệu...”. C đóng tab.) C: Vậy là web bên ngoài vừa khiến EduPortal thực hiện thao tác bằng phiên đăng nhập của mình? Để note lại lỗi này. C: Test tới đây coi như tạm ổn phần chính. Còn cái ô tìm mã sinh viên nữa...
	7. Hiện thị chi tiết mã lỗi truy vấn SQL ra màn hình người dùng		(C nhập một chuỗi ký tự lạ vào ô tìm kiếm. Màn hình bật khối chữ dài: <code>Error: SQLSTATE[42000]... near "SELECT * FROM diem WHERE ma_sv = '12a'".</code>) C: Cái gì đây... nó hiện luôn cả cấu trúc bên trong. Web này đúng kiểu cái gì cũng để lộ.
	10. Để lộ mật khẩu kết nối Database trong file HTML		C: Test xong phần tìm kiếm rồi, giờ qua trang thông tin chung coi UI ổn không. (C bấm chuột phải, chọn "Xem mã nguồn trang" — thao tác test UI bình thường. Cuộn xuống, thấy dòng comment sót lại: <code><!-- DB_HOST=localhost DB_USER=root DB_PASS=Edu@2024 --></code>.) C: (dừng lại) ...cái này là gì vậy? Thông tin đăng nhập database nằm ngay trong code gửi về trình duyệt luôn á? (C định báo ngay cho A, rồi dừng tay, chụp màn hình lưu riêng.) ...để coi thử cái này dùng được gì không đã, báo sau.
	11. Lộ cấu trúc thư mục Git ra môi trường web.		C: Thử coi cái thư mục git lúc đẩy code lên server còn sót không ha. (C gõ <code>eduportal.edu/git/config</code>. Trang hiện toàn bộ nội dung file cấu hình mã nguồn.) C: Còn luôn á? Vậy ai rảnh cũng lấy được nguyên code tại mình viết luôn chứ gì. (lại định báo, rồi thôi) Thôi, để tổng hợp một lượt rồi báo luôn cho gọn.

	12. Cấu hình CORS lỏng lẻo cho phép mọi domain gọi API.	(C vẫn đang đăng nhập EduPortal. C mở một trang test khác có tên test-site.edu.) C: Để coi API có cho website bên ngoài đọc dữ liệu không. (C chạy đoạn JavaScript test. Request gọi đến:) https://eduportal.edu/api/diem (Trong DevTools, Response Headers hiển thị:) Access-Control-Allow-Origin: * (Trang test hiển thị dữ liệu điểm của tài khoản đang đăng nhập.) Dữ liệu trả về: Nguyễn A Cơ sở dữ liệu: 8.5 An toàn thông tin: 9.0 ... C: Ở... trang ngoài EduPortal mà vẫn đọc được response API luôn? Để lưu lại lỗi này luôn	
	13. Dùng thư viện JavaScript cũ dính lỗ hổng.	(C mở tab Console để xem log trong lúc test giao diện, thấy dòng cảnh báo: "jQuery 1.8.3 — deprecated, known vulnerabilities".) C: Ủa sao Console cứ cảnh báo cái này vậy ta. (C tra tên phiên bản trên Google, ra hàng loạt bài viết về lỗ hổng công khai (CVE) của bản này.) C: (trầm ngâm) Thư viện cũ vậy mà tui mình vẫn còn dùng à... đúng ra phải update lâu rồi.	
	14. Mã JWT Token sinh ra không được mã hóa an toàn.	(C mở DevTools → Application → Local Storage và lấy JWT đang sử dụng.) C: Để coi token này được xác thực kiểu gì. (C decode JWT. Payload hiện:) <pre>{ "ma_sv": "SV001", "role": "sinhvien" }</pre> C: Payload đọc được thì bình thường... JWT đầu nhất thiết phải mã hóa nội dung. (C thử thay payload role từ sinhvien thành admin, sau đó gửi request bằng token đã bị sửa.) <pre>{ "ma_sv": "SV001", "role": "admin" }</pre> (Server vẫn trả 200 OK. C truy cập được trang quản trị.) C: Khoan... Token bị sửa rồi mà server vẫn chấp nhận? C: Vậy backend không kiểm tra chữ ký token đúng cách rồi.	

Cảnh 3	8. API lộ thông tin cá nhân của giảng viên		(B mở mục "Danh sách giảng viên" trên EduPortal.) B: Để cô xem thử phần thông tin giảng viên. Em bấm vào cô này cho cô coi. (A bấm vào tên một giảng viên. Thông tin cơ bản hiện ra.) B: Ừ, phần này hiện bình thường. Nhưng dữ liệu này lấy ở đâu vậy em? A: Dạ, em lấy từ API của hệ thống ạ. Ví dụ giảng viên này có mã 12 thì đường dẫn là: eduportal.edu/api/giangvien/12 nè cô. B: Vậy để cô thử mở thẳng đường dẫn đó xem. (B copy đường dẫn, mở một tab ẩn danh để chắc chắn không có đăng nhập.) Màn hình hiện: <pre>{ "ho_ten": "Nguyễn Văn A", "so_dien_thoai": "09xxxxxxx", "dia_chi": "..."} </pre> B: Ừa? Không đăng nhập mà vẫn xem được? Với nó trả cả số điện thoại với địa chỉ luôn này. A: Chắc lúc làm API em cho nó trả hơi nhiều dữ liệu. B: Ừ, cái này phải coi lại. Người ngoài đâu được biết hết mấy thông tin này. A: Dạ... để em sửa sau ạ.	
	9. Không giới hạn số lần nhập sai mật khẩu (Brute-force).	Vài ngày sau, văn phòng khoa. A và B rà hệ thống trước khi công bố rộng cho cả khoa. C lảng vảng gần đó, giả vờ bận vì đã biết trước những lỗi này qua đợt test nhưng chưa báo lại.	(B mở lại trang đăng nhập) B: Để cô thử thêm cái này. (B thử vui, cố tình gõ sai mật khẩu liên tục 15 lần ở trang đăng nhập. Không có cảnh báo, không bị khóa, lần thứ 16 cô gõ đúng vẫn vào bình thường.) B: Sao nhập sai cả chục lần mà nó không khóa tài khoản vậy? A: (bận gõ chỗ khác) Dạ để em thêm sau, giờ deadline gấp quá cô ơi.	
	15. Bật chế độ Debug hiển thị lỗi trên server thật.		(A quay lại làm việc, màn hình hiện một trang lỗi dài với đường dẫn file, số dòng code cụ thể.) A: Ừa sao lỗi này lại hiện chi tiết vậy ta... B: Chắc do em để chế độ debug từ hồi code cho dễ tìm lỗi, quên tắt lại khi đẩy lên server thật rồi. A: (gãi đầu) Dạ, để em tắt. (C nhìn màn hình đó lướt qua, ghi nhận thêm một lỗi vào danh sách riêng.)	
	16. Thiếu các HTTP Security Headers cơ bản.		(B mở DevTools → Network → chọn request trang chủ EduPortal → Response Headers.) B: Để cô kiểm tra mấy HTTP header bảo mật xem. (Màn hình hiện các response header nhưng không có X-Frame-Options hoặc CSP frame-ancestors.) B: Không thấy X-Frame-Options, cũng không có frame-ancestors. A: Hai cái đó dùng để ngăn trang bị nhúng vào iframe đúng không cô? B: Ừ. Để cô thử luôn. (B mở một file test.html có iframe trỏ tới EduPortal.) <pre><iframe src="https://eduportal.edu"></iframe></pre> (EduPortal hiện nguyên trang bên trong iframe.) B: Nhúng vào bình thường thật rồi này. Lỡ ai làm giả một trang y hệt rồi nhúng cái này vào, sinh viên đâu biết mình đang bấm nhầm trang giả. A: Dạ, để em note lại lỗi.	

Cảnh 4	17. Truyền Session ID lộ liễu trên thanh URL.	Vấn vấn phòng khoa, ngay sau đó.	(A mở một đường dẫn EduPortal mà C từng gửi.) Trên thanh địa chỉ hiện: https://eduportal.edu/dashboard?session=8f3a1c9d0e... B: (xem link, thấy đoạn &session=8f3a1c9d0e... ngay giữa URL) Cái này... sao đường link đọc tài liệu bình thường lại có nguyên đoạn mã phiên đăng nhập của em nằm ngay trên URL vậy? A: (chợt hiểu, mặt tái đi) Ủa... vậy ai có cái link này là vào được tài khoản em luôn? B: Link này còn có thể bị lưu vào lịch sử trình duyệt, log hoặc bị chia sẻ nhầm nữa.	
	18. Không tự động thu hồi Cookie khi đăng xuất.		B: Để cô test thử coi sau khi đăng xuất session đó còn dùng được không. <i>(A bấm "Đăng xuất". B lấy đúng link C gửi hôm trước, mở trên máy khác — vẫn vào được thẳng tài khoản A dù đã đăng xuất.)</i> B: (thở dài) Đăng xuất hần hoi rồi mà phiên cũ vẫn còn dùng được á. Đăng xuất coi như chỉ đóng giao diện thôi, chứ đâu thật sự khóa lại gì đâu.	
	19. Bỏ qua bước kiểm duyệt đề tài của trưởng bộ môn bằng cách sửa tham số.		(C đăng nhập bằng tài khoản sinh viên. C đang ở trang đề tài của mình, trạng thái hiện "Chờ duyệt".) Đề tài #87 Trạng thái: Chờ duyệt (C mở DevTools → Network, chọn request cập nhật đề tài.) PUT /api/detai/87 Request: <pre>{ "trang_thai": "cho_duyet" }</pre> C: À, trạng thái nằm ngay trong request. Để sửa thử coi. (C sửa trực tiếp thành:) <pre>{ "trang_thai": "da_duyet" }</pre> (C gửi request.) 200 OK (Trang reload. Trạng thái chuyển thành "Đã duyệt".) C: Ủa... sửa được thật à... (C nhìn màn hình một lúc rồi đóng DevTools.)	
	20. Chỉ xác thực dữ liệu đầu vào bằng JavaScript ở client thay vì backend.		A: (mở Network tab kiểm tra log request) Để em coi log request thử... <i>(A thấy request PUT gửi thẳng lên server: {"ma_de_tai": 87, "trang_thai": "da_duyet"} — không đi qua nút bấm nào trên giao diện, gửi từ tài khoản C.)</i> A: Cái này đâu phải bấm nút trên web ra được, phải tự tay soạn hần một yêu cầu gửi thẳng lên server mới ra vậy chứ. Mà sao gửi vậy vẫn được server chấp nhận luôn, đâu ai kiểm tra lại gì hết á?	

	(A và B quay sang nhìn C.) C: (nghe ngào, ngồi sụp xuống ghế) Dạ... em xin lỗi cô, xin lỗi A. Em test giùm mà phát hiện toàn lỗi, em định báo lại... nhưng em đang trượt đề tài, em sợ quá nên... B: (giọng trầm, không giận dữ) Quân, cô hiểu áp lực của em. Nhưng đáng lẽ ra, chính lúc em phát hiện những lỗi này trong lúc test, đó là cơ hội để em giúp cả nhóm sửa nó — không phải cơ hội để lợi dụng. A: (thăm thía) Mà đúng thật ha cô, tụi em cũng đâu phải không biết cách sửa, mà cứ mỗi lần thấy gì lạ lúc demo, tụi em đều nghĩ "thôi kệ, để sau" rồi cho qua... B: Và đó chính là điều nguy hiểm nhất, không phải vì không ai biết cách sửa, mà vì không ai chịu dừng lại để sửa ngay khi vừa phát hiện điều bất thường.
--	---